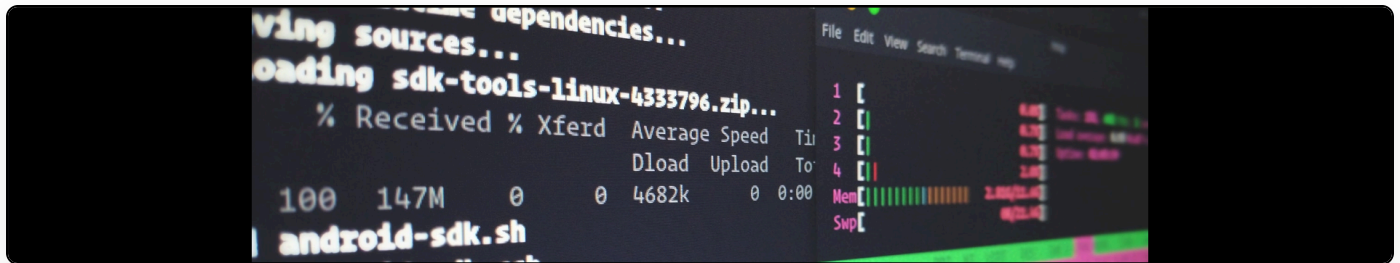


JavaScript Referrer Scripts XSS Injection

Cite as: Martin Paul Eve, "JavaScript Referrer Scripts XSS Injection", *eve.gd: Martin Paul Eve*, May 15, 2007, <https://doi.org/10.59348/877mz-7q690>.



Many sites use JavaScript methods to inject a hidden form field into 404 pages to trace the original page that points to the invalid link. An example of this can be found at <http://www.yaldex.com/FSPageDetails/404Referrer.htm>. The attentive observer will spot that this method of writing the field injects the HTTP referrer directly into the page without any sanitization.

So what? It is very difficult to forge referrers from a malicious website, however, with the help of the mod_rewrite apache module it is possible to create referrer strings which contain malicious strings.

The process for exploitation is as follows:

1. Create a .htaccess file that specifies a mod rewrite that includes a capture. For example:
RewriteRule XSSReferer/(.+) \$ /xss_test_referer.htm. This will forward all requests to the XSSReferer directory to xss_test_referer.htm. In this case a page with a link to the target. Note that because mod_rewrite is used the referrer is NOT xss_test_referer.htm but the originally entered url.
2. Visit the virtual RewriteRule with a malicious string. An example for IE7 is [http://www.md5-db.com/XSSReferer/'style=xx:expression\(alert\(1\)\);othervar='](http://www.md5-db.com/XSSReferer/'style=xx:expression(alert(1));othervar=') which will display a standard XSS test and probably crash your browser.

Note that this is far harder to exploit in Firefox. This is because of the way the URLs are encoded, making it very difficult to inject anything other than a style tag and, as mentioned in my previous post, Firefox does not yet support loading of XBL documents without a fragment identifier.

To protect against this type of injection you should always filter ANY input passed directly to the page... even HTTP headers.